

СОДЕРЖАНИЕ

ВВЕДЕНИЕ.....	3
1 КРАТКИЙ РАЗБОР НОРМАТИВНЫХ ДОКУМЕНТОВ.....	3
1.1 Термины и концепция защиты от НСД.....	3
1.2 Классификация автоматизированных систем.....	4
1.3 Классы СВТ.....	5
1.4 Классы межсетевых экранов.....	6
1.5 Федеральный закон № 187-ФЗ.....	7
1.6 Методика оценки угроз безопасности информации (05.02.2021).....	7
2 ПОРЯДОК РЕШЕНИЯ ТАКИХ ЗАДАЧ.....	8
3 РЕШЕНИЕ КЕЙСОВ.....	9
3.1 Кейс 1. Завод автомобильных деталей.....	9
3.2 Кейс 2. Городской архив.....	10
3.3 Кейс 3. ИП, секреты производства, один человек.....	11
3.4 Кейс 4. Компания больше 100 человек, закрытая сеть.....	12
3.5 Кейс 5. Информационная сеть с доступом из Интернета.....	12
3.6 Кейс 6. Государственное предприятие, архив с грифами СС и С.....	14
3.7 Кейс 7. Государственная энергокомпания и троян-стилер.....	15
4 СВОДНАЯ ТАБЛИЦА ПО ВСЕМ КЕЙСАМ.....	17
ЗАКЛЮЧЕНИЕ.....	17
СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ.....	19

ВВЕДЕНИЕ

Цель работы — изучить основные руководящие документы ФСТЭК (Гостехкомиссии) по защите от НСД и научиться применять их на практике. Нужно уметь выбрать класс автоматизированной системы (АС), класс средств вычислительной техники (СВТ) и класс межсетевого экрана (МЭ). Ещё надо понять, в каком порядке эти задачи решать.

Для достижения указанной цели необходимо решение следующих задач:

- ознакомиться с РД «Защита от НСД. Термины и определения» и с Концепцией защиты от НСД;
- изучить РД «Автоматизированные системы. Защита от НСД» (классификация АС, 30.03.1992);
- изучить РД «Средства вычислительной техники. Защита от НСД» (показатели защищенности СВТ);
- изучить РД «СВТ. Межсетевые экраны. Защита от НСД» (25.07.1997);
- учесть Федеральный закон от 26.07.2017 № 187-ФЗ «О безопасности критической информационной инфраструктуры Российской Федерации»;
- учесть методический документ ФСТЭК «Методика оценки угроз безопасности информации» (утв. 05.02.2021);
- по каждому из семи кейсов обосновать класс АС, класс СВТ и класс МЭ;
- сделать вывод, в каком порядке начинать решение таких задач.

1 КРАТКИЙ РАЗБОР НОРМАТИВНЫХ ДОКУМЕНТОВ

1.1 Термины и концепция защиты от НСД

РД по терминам задает язык, на котором написаны остальные документы. Без него легко перепутать субъекта доступа и пользователя, НСД и утечку. Для лабы хватит нескольких определений.

- несанкционированный доступ (НСД) — доступ к информации, который нарушает правила разграничения доступа;
- правила разграничения доступа (ПРД) — правила, кто к каким объектам имеет право обращаться;
- СЗИ НСД — система защиты от НСД: программы, техника и организационные меры вместе;
- идентификация / аутентификация — узнать субъекта и проверить, что это он;
- дискреционное и мандатное управление доступом — два основных способа разграничить права.

Концепция защиты от НСД класс конкретной системы не ставит. Она про то, как защиту строить. Одного антивируса или одного пароля мало. СЗИ НСД лучше закладывать при создании АС, а не после первой утечки. Ещё нужен ответственный за защиту, охрана помещений, учет носителей и контроль, какое ПО можно запускать.

1.2 Классификация автоматизированных систем

РД «Автоматизированные системы. Защита от НСД» (решение Гостехкомиссии России от 30.03.1992) вводит девять классов защищенности АС. Класс берут не по размеру завода, а по трём признакам (п. 1.7–1.9): какой уровень конфиденциальности у информации (гостайна / конфиденциальная / открытая); какие полномочия у пользователей: все ли видят всё; режим обработки: один пользователь или несколько.

По этим признакам АС делят на три группы. Третья группа — однопользовательские АС: работает один человек, он допущен ко всей информации на носителях одного уровня конфиденциальности; классы 3Б и 3А. Вторая группа — пользователи имеют одинаковые права ко всей информации, носители могут быть разного уровня; классы 2Б и 2А. Первая группа — многопользовательские АС, информация разных уровней лежит вместе, и не все имеют доступ ко всему; классы 1Д, 1Г, 1В, 1Б, 1А.

Внутри группы «А» всегда строже «Б», а в первой группе 1А строже 1Д. Пункт 2.18 говорит прямо: если есть гостайна, класс не ниже 3А, 2А, 1В, 1Б или 1А, смотря какая группа. Значит 3Б, 2Б, 1Г и 1Д — это уже не гостайна, а конфиденциальная или открытая информация. Таблица «гриф — класс» есть в разборе на Хабре [7], она совпадает с п. 2.18 (таблица 1).

Таблица 1 – Группы и классы АС по РД 1992 г.

Группа	Кто работает в АС	Права доступа	Классы (слабее → строже)
3	Один пользователь	Допущен ко всей информации одного уровня	3Б, 3А
2	Несколько пользователей	Одинаковые права ко всей информации	2Б, 2А
1	Несколько пользователей	Не все имеют доступ ко всей информации	1Д, 1Г, 1В, 1Б, 1А

Данные приведены ниже (таблица 2).

Таблица 2 – Привязка класса АС к грифу информации (по п. 2.18 и [7])

Условие	ОВ	СС	С	Конфид. (не ГТ)	Открытая
Один пользователь	3А	3А	3А	3Б	3Б
Равные права у всех	2А	2А	2А	2Б	2Б
Права разные	1А	1Б	1В	1Г	1Д

СЗИ НСД в этом РД делят на четыре подсистемы: управление доступом, регистрация и учет, криптография и целостность. Чем выше класс, тем жёстче требования. Для кейсов достаточно помнить: выше класс — строже идентификация, разграничение, журнал событий, контроль целостности ПО и охрана компьютеров.

1.3 Классы СВТ

РД «Средства вычислительной техники. Защита от НСД» вводит семь классов защищенности СВТ: 1-й — самый высокий, 7-й — самый низкий.

Это уже не класс системы целиком, а класс конкретного компьютера: какие там идентификация, очистка памяти, контроль запуска задач и т.д. Для гостайны п. 2.18 РД по АС минимум пишет явно:

- АС класса 1В — СВТ не ниже 4 класса;
- АС класса 1Б — СВТ не ниже 3 класса;
- АС класса 1А — СВТ не ниже 2 класса.

Для остальных случаев удобно идти от грифа, как в таблице [7]: особой важности — СВТ 1–2, совершенно секретно — 3, секретно — 4, конфиденциальная информация — 5, ниже — 6. Седьмой класс ещё слабее шестого, для конфиденциальных данных его обычно не берут.

1.4 Классы межсетевых экранов

РД «СВТ. Межсетевые экраны. Защита от НСД» (25.07.1997) вводит пять классов МЭ. 5-й — самый низкий, 1-й — самый высокий. В п. 1.5–1.6 расписано, какой МЭ к какой АС: 1Д — МЭ 5 класса; 1Г — 4; 1В — 3; 1Б — 2; 1А — 1; для АС 3Б и 2Б — МЭ не ниже 5 класса; для АС 3А и 2А: гриф «секретно» — не ниже 3, «совершенно секретно» — не ниже 2, «особой важности» — не ниже 1.

В том же пункте сказано: требования к МЭ не отменяют требования к СВТ и АС. Если АС закрытая и внешней сети нет, МЭ на границе с интернетом можно не ставить. Класс МЭ всё равно указывают: вдруг понадобится стык с другой сетью или передача данных. Добавление МЭ не должно понижать класс АС (таблица 3).

Таблица 3 – Соответствие классов АС, СВТ и МЭ

Класс АС	Типовой гриф / режим	СВТ не ниже	МЭ не ниже
1А	Разные права, особая важность	2	1
1Б	Разные права, совершенно секретно	3	2
1В	Разные права, секретно	4	3

1Г	Разные права, конфиденциально	5	4
1Д	Разные права, неконфиденциально	6	5
2А	Равные права, гостайна	по грифу: 4 / 3 / 2	по грифу: 3 / 2 / 1
2Б	Равные права, конфиденциально / открыто	6	5
3А	Один пользователь, гостайна	по грифу: 4 / 3 / 2	по грифу: 3 / 2 / 1
3Б	Один пользователь, конфиденциально / открыто	6	5

1.5 Федеральный закон № 187-ФЗ

Закон № 187-ФЗ — это уже не класс компьютера, а правила для критической информационной инфраструктуры (КИИ). Он не вместо РД по АС/СВТ/МЭ, а поверх них. Включается, если объект из сфер КИИ (энергетика, транспорт, связь, банки, здравоохранение и т.д.) или если сбой системы бьет по государству, экономике, обороне.

Из 187-ФЗ для лабы нужны четыре вещи. Субъект КИИ должен найти объекты КИИ и категорировать значимые. Для значимых объектов действуют требования ФСТЭК (и где надо — ФСБ). О компьютерных инцидентах нужно сообщать. Оценку угроз для таких систем делают по методике ФСТЭК от 5 февраля 2021 г.

1.6 Методика оценки угроз безопасности информации (05.02.2021)

Методика идет на ГИС, ИСПДн, значимые объекты КИИ, АСУ ТП на опасных объектах и в ряде других случаев. Классификацию АС 1992 года она не заменяет. Вопрос другой: какие угрозы реальны для уже понятной системы и какие меры из-за этого ставить.

Порядок оценки (разд. 2 Методики) такой: сначала последствия, потом инвентаризация систем и объектов воздействия, потом источники угроз и возможности нарушителя, потом способы реализации, актуальность и

сценарии. Исходные данные — БДУ ФСТЭК, документация на систему, состав информации и её правовой режим, описание процессов. На этапе создания оценка нужна, чтобы выбрать меры и СЗИ. На этапе эксплуатации — чтобы проверить, работают ли уже поставленные меры.

Методику не стоит ставить первым шагом вместо классификации. Сначала надо понять, какая информация и какая АС. Иначе непонятно, какие последствия считать плохими. И наоборот: одного класса 1Г мало, если система в интернете и в ней ПДн или КИИ. Угрозы всё равно надо оценить.

2 ПОРЯДОК РЕШЕНИЯ ТАКИХ ЗАДАЧ

По Концепции, п. 2.17 РД по АС и разделу 2 Методики 2021 г. я дальше иду так.

- шаг 1. Правовой режим информации. Есть ли гостайна (и какой гриф), конфиденциальные сведения (коммерческая / производственная тайна, ПДн), открытые данные, признаки объекта КИИ по 187-ФЗ;
- шаг 2. Кто работает в АС. Сколько пользователей, одинаковые ли права, есть ли доступ «не ко всему»;
- шаг 3. Класс АС по трём признакам РД 1992 г. (группа 1 / 2 / 3 и буква класса);
- шаг 4. Класс СВТ — по п. 2.18 и грифу, не ниже таблицы 3;
- шаг 5. Класс МЭ — если есть (или будет) связь с внешней / соседней сетью. Для закрытой системы класс всё равно пишут, на случай стыка;
- шаг 6. Если есть КИИ или ИСПДн / ГИС — 187-ФЗ и/или отраслевые требования, категоризация, ГосСОПКА;
- шаг 7. Оценка угроз по Методике 05.02.2021 и уже под них состав СЗИ НСД (доступ, регистрация, крипто, целостность) плюс организационные меры.

Частая ошибка — сразу писать «нужен файрвол» или «поставим антивирус», не глядя на гриф и число пользователей. Тогда можно промахнуться с группой АС, и классы СВТ и МЭ тоже будут не те.

3 РЕШЕНИЕ КЕЙСОВ

3.1 Кейс 1. Завод автомобильных деталей

Негосударственный завод уходит с бумаги на электронный документооборот. В отделе кадров есть персональные данные сотрудников. Компьютерами пользуются бухгалтерия, кадры и директор: бухгалтеры видят только «цифры», кадровики — только «характеристики». Отдельно надо закрыть сведения о поставщиках: конкуренты уже пытались украсть их через «своих» людей, которых устраивали на завод.

Шаг 1. Гостайны нет. Есть персональные данные и коммерческая тайна о поставщиках. Это конфиденциальная информация, не ГТ. КИИ по 187-ФЗ из условия не видно: обычное машиностроение в перечень сфер КИИ само по себе не входит.

Шаг 2. Пользователей несколько, права разные: бухгалтер не должен читать личные характеристики, кадровик — не всю бухгалтерию, у директора права шире. Значит это не 2-я и не 3-я группа, а 1-я: не все видят всё, и сведения разных уровней (ПДн, коммерческая тайна, обычный документооборот).

Шаги 3–5. Класс АС — 1Г. СВТ — не ниже 5 класса. МЭ — не ниже 4 класса (п. 1.5 РД по МЭ для АС 1Г). Даже если сеть сейчас в основном внутренняя, электронный документооборот почти всегда тянет почту, банк-клиент или обмен с поставщиками. Без МЭ 4 класса стык с внешней средой для 1Г не проходит.

По Концепции и РД АС нужны идентификация, разграничение «бухгалтерия / кадры / директор», журнал доступа к карточкам поставщиков и ПДн, контроль целостности ПО (против схемы «устроили своего»). Для 1Г обязательна охрана СВТ: контроль входа в помещения, особенно ночью. Это прямое требование класса и ответ на уже бывшие попытки кражи (таблица 4).

Таблица 4 – Кейс 1, выбранные классы

АС	СВТ не ниже	МЭ не ниже	Почему не другой класс
1Г	5	4	Разные права + конфиденциально (ПДн, коммерческая тайна), не ГТ

3.2 Кейс 2. Городской архив

Штат архива сократили до одного человека — директора. Фонд уже на электронных носителях. Директор и руководство города имеют доступ ко всей информации архива, включая сведения под грифом «совершенно секретно».

Шаг 1. Высший гриф — «совершенно секретно». Это гостайна. По п. 2.18 РД по АС класс не ниже ЗА / 2А / 1Б, смотря какая группа. 187-ФЗ здесь вторичен: сначала режим секретности, и уже потом вопрос, является ли архив ещё и объектом КИИ (для городского архива это не обязательно).

Шаг 2. Формально сотрудник один, но доступ есть и у директора, и у руководства города, права одинаковые — ко всей информации, включая СС. Это 2-я группа: несколько пользователей с равными правами, носители разного уровня. Если бы руководство города получало только бумагу, без учетных записей в АС, можно было бы взять ЗА. По тексту кейса доступ к информации в архиве есть у нескольких лиц, поэтому беру 2-ю группу.

Шаги 3–5. Класс АС — 2А (гостайна, равные права). Гриф СС: СВТ не ниже 3 класса, МЭ не ниже 2 класса. Саму архивную АС лучше держать без интернета, но МЭ 2 класса нужен на любом разрешенном стыке (сеть города, передача в другой аттестованный контур). Охрана для 2А жёсткая: постоянная охрана здания, пропускной режим, специальное оборудование помещений. Это прямо написано в требованиях к 2А, это не «замок на кабинете» (таблица 5).

Таблица 5 – Кейс 2, выбранные классы

АС	СВТ не ниже	МЭ не ниже	Почему не другой класс
2А	3	2	Несколько субъектов с равным доступом ко всей информации, гриф СС

3.3 Кейс 3. ИП, секреты производства, один человек

Индивидуальный предприниматель работает один, хочет сохранить секреты производства и автоматизировать документооборот. Доступ ко всей информации должен быть только у него, но кабинет арендованный: он боится, что в его отсутствие кто-то всем воспользуется.

Шаг 1. Секреты производства — конфиденциальная информация (коммерческая / производственная тайна), гостайны нет. КИИ нет.

Шаг 2. Пользователь один, он допущен ко всей информации. Это 3-я группа. По п. 2.18 класс 3А берут под гостайну, поэтому без ГТ выбираю 3Б.

Шаги 3–5. Класс АС — 3Б. СВТ не ниже 6 класса. МЭ не ниже 5 класса — на случай почты, облака, банк-клиента. Если документооборот полностью локальный, внешний стык можно не делать, но тогда и флешки из кабинета не выносить. Риск тут даже не в «слабом» классе, а в физическом доступе к компьютеру. Для 3Б нужна охрана, контроль посторонних в помещении и защита в нерабочее время. В аренде это сейф или запираемый шкаф для системника и носителей, блокировка консоли, шифрование диска, нельзя оставлять сессию открытой. Без этого формальный класс 3Б не выполняется, хотя пользователь один (таблица 6).

Таблица 6 – Кейс 3, выбранные классы

АС	СВТ не ниже	МЭ не ниже	Почему не другой класс
3Б	6	5	Один пользователь, нет ГТ; 3А была бы при секретной информации

3.4 Кейс 4. Компания больше 100 человек, закрытая сеть

Штат больше 100 человек, единая система передачи данных без выхода в интернет. В небольших кабинетах сотрудники легко садятся за чужие компьютеры. У руководителей есть доступ к сведениям, которых нет у остальных. Конфиденциальная информация по условию в системе не передается.

Шаг 1. Конфиденциальной информации нет, гостайны нет. Обработываются открытые сведения. КИИ из условия не видно.

Шаг 2. Пользователей много, права разные (руководство видит то, чего не видят рядовые). Это 1-я группа. Сведения неконфиденциальные — класс 1Д, а не 1Г.

Шаги 3–5. Класс АС — 1Д. СВТ не ниже 6 класса. МЭ не ниже 5 класса: сейчас выхода в интернет нет, но РД по МЭ описывает безопасное взаимодействие АС 1Д с внешней средой. Класс фиксируем, сам экран ставят в момент любого подключения. Если сеть совсем изолирована, дыры не в МЭ, а в чужих рабочих местах. Для 1Д всё равно нужны идентификация, блокировка сеанса и контроль доступа к компьютерам. Иначе разграничение прав руководителей обнуляется тем, что сосед сел за открытый ПК (таблица 7).

Таблица 7 – Кейс 4, выбранные классы

АС	СВТ не ниже	МЭ не ниже	Почему не другой класс
1Д	6	5	Разные права, конфиденциальная информация не передаётся

3.5 Кейс 5. Информационная сеть с доступом из Интернета

Несколько сотрудников, документооборот через «сеть», по ней можно передавать любую информацию любому пользователю, в том числе

производственную тайну. Вход — с любого устройства из интернета через приложение.

Шаг 1. Производственная тайна — конфиденциально, не ГТ. Плюс доступ из открытой сети, то есть снаружи кто угодно может стучаться.

Шаг 2. Как систему описали, права у всех равные: любой может получить любую информацию. Это 2-я группа и класс 2Б. Но задание просит предложить вариант, который проходит по требованиям безопасности. Не закреплять схему, где тайна доступна всем с любого телефона. При нескольких сотрудниках производственную тайну обычно нельзя раздавать всем подряд — это уже 1-я группа. Как нормальную АС предлагаю 1Г: разные права, конфиденциальные сведения. Класс 2Б оставляю только как «как задумали сейчас». Он всё равно не спасает схему «любое устройство из интернета».

Шаги 3–5. Нужные классы: АС 1Г, СВТ не ниже 5, МЭ не ниже 4. Доступ только с рабочих СВТ своего класса, не с личного телефона из кафе. МЭ 4 класса — на границе приложения и интернета (фильтрация, регистрация; для 4 класса МЭ регистрация уже обязательна, для 3-го появляется ещё идентификация на самом экране). Клиент на чужой машине ломает и класс СВТ, и охрану, и контроль целостности. Это не «удобный облачный сервис», а вывод конфиденциальной АС за периметр. По Методике 2021 г. тут внешний нарушитель, подбор паролей, вредоносное ПО на чужом устройстве, утечка производственной тайны (таблица 8).

Таблица 8 – Кейс 5, выбранные классы

Вариант	АС	СВТ	МЭ	Комментарий
Как описали (равный доступ)	2Б	6	5	Формально по правам, но схема с любым устройством класс не выдерживает

Как нужно сделать	1Г	5	4	Разграничить доступ к тайне, только рабочие СВТ, МЭ на периметре
-------------------	----	---	---	--

3.6 Кейс 6. Государственное предприятие, архив с грифами СС и С

Закрытая от внешней среды система. Пользуется ею один человек — заведующий архивом. В архиве есть сведения «совершенно секретно» и «секретно», возможна их дистрибуция. Вход только со специального ПК в архиве после авторизации.

Шаг 1. Государственная тайна, высший гриф — СС. Это сразу отсекает ЗБ/2Б/1Г/1Д. Государственное предприятие с секретным делопроизводством может пересекаться с КИИ, но для выбора класса АС достаточно грифа.

Шаг 2. В АС работает один пользователь, он допущен ко всей информации. Дистрибуция — это передача в другой контур или на другие носители, а не второй оператор этой же АС. Значит 3-я группа и, раз есть ГТ, класс ЗА (п. 2.18: для секретной информации не ниже ЗА).

Шаги 3–5. Класс АС — ЗА. По грифу СС: СВТ не ниже 3 класса, МЭ не ниже 2 класса. Интернет не нужен и вреден. МЭ 2 класса ставят не «чтобы сидеть в соцсетях», а на разрешенном стыке при дистрибуции, если вообще есть сетевая передача в соседнюю аттестованную АС. Если дистрибуция только на учтенных носителях через «воздушный зазор», сетевого МЭ может не быть, но тогда нужны учет носителей, очистка памяти СВТ и охрана архива. Авторизация на специальном ПК — это идентификация и аутентификация, без них ЗА не выполняется. Одного факта «компьютер стоит в архиве» мало (таблица 9).

Таблица 9 – Кейс 6, выбранные классы

АС	СВТ не ниже	МЭ не ниже	Почему не другой класс
----	-------------	------------	------------------------

3А	3	2	Один пользователь + гостайна СС; 2А была бы при нескольких равных пользователях
----	---	---	---

3.7 Кейс 7. Государственная энергокомпания и троян-стилер

Госэнергокомпания снабжает электроэнергией страну. Новый специалист по ИБ нашёл троян-стилер: кто-то из автоматизации скачал поддельный установщик IDE. Утекли данные клиентов, внутренние метрики, платежные данные, включая номера карт и CVV. Эти сведения «видны любому желающему». Вопрос кейса: какие требования РД ФСТЭК не соблюдал сотрудник (и по сути оператор системы).

Шаг 1. Сразу несколько режимов. Электроэнергетика — сфера КИИ, 187-ФЗ идет хотя бы на объекты управления и связанные ИТ-системы. Данные клиентов — персональные данные. Номера карт и CVV — сведения ограниченного доступа, это не «просто внутренняя статистика». Госэнергокомпания, скорее всего, ещё обрабатывает служебную / коммерческую информацию. Гостайна из условия прямо не названа, поэтому базовый класс АС по грифу — конфиденциальный, не 1В.

Шаг 2. Пользователей много, «любому желающему видны» ПДн и платежные данные — это уже сломанное разграничение. Как надо: разные права (1-я группа), конфиденциально — АС 1Г, СВТ не ниже 5, МЭ не ниже 4. Сейчас система ведёт себя хуже 1Д: нет ни разграничения, ни контроля запуска программ, ни границы с внешней средой.

Сотрудник, скачавший фейковый установщик, нарушил подсистему целостности СЗИ НСД и правила работы с ПО. В АС должно стоять только разрешенное (для высоких классов — сертифицированное / контролируемое) ПО, нужен контроль целостности программ и запрет запуска задач, которые не прошли проверку. «Скачал IDE с зеркала в интернете» на машине, с которой видна клиентская база — это НСД со стороны вредоносного кода, даже если человек «не хотел украсть».

Сводить кейс только к одному сотруднику нельзя. РД писали про систему защиты, а не про «пусть пользователь будет аккуратнее» (таблица 10).

Таблица 10 – Кейс 7, нарушенные требования

Документ	Что не соблюдено
Концепция защиты от НСД	Нет нормальной СЗИ: защита не заложена в работу, нет контроля, какое ПО пускают в контур, инцидент разбирают после утечки
РД по АС (доступ)	Нет рабочих ПРД: ПДн, метрики и платежные данные доступны «любому желающему». Для 1Г разграничение и идентификация обязательны
РД по АС (регистрация)	Нет регистрации запуска ПО, доступа к карточкам клиентов и выгрузки данных
РД по АС (целостность)	Нет контроля целостности ПО и запрета неучтённых программ. Поддельный установщик IDE не должен был запускаться
РД по СВТ	Не выполнены показатели идентификации, контроля запуска задач, очистки. Машина без класса видит контур с ПДн
РД по МЭ	Либо МЭ нет, либо он ниже требуемого класса. Для АС 1Г нужен МЭ не ниже 4 класса, с регистрацией соединений
187-ФЗ	Энергокомпания — субъект КИИ. Не обеспечена безопасность объекта (ст. 9): категоризация, меры защиты, ГосСОПКА
Методика 05.02.2021	Не оценены актуальные угрозы: внешний нарушитель, вредоносное ПО, компрометация рабочего места, утечка ПДн

Про специалиста ИБ из условия. Искать зараженные машины — нормально. Но только «предупредить владельца» мало: хост надо изолировать, сессии сбросить, канал утечки разобрать. Угроза уже сработала, ПДн и платежные данные утекли, сценарий известен, а мер против этого нет. Методика 2021 г. требует выбрать меры под актуальные угрозы. Одно предупреждение контур не защищает.

По кейсу 7. Нужные классы: АС 1Г, СВТ не ниже 5, МЭ не ниже 4, плюс режим КИИ по 187-ФЗ и модель угроз по Методике 05.02.2021. Не соблюдены разграничение доступа, целостность ПО, периметр и разбор

инцидента. Сотрудник автоматизации дал вход трояну. Оператор системы не выполнил почти весь минимум РД.

4 СВОДНАЯ ТАБЛИЦА ПО ВСЕМ КЕЙСАМ

Данные приведены ниже (таблица 11).

Таблица 11 – Предлагаемые классы защищенности

Кейс	Информация	Пользователи / права	АС	СВТ	МЭ
1. Завод деталей	ПДн, коммерческая тайна	Несколько, права разные	1Г	5	4
2. Городской архив	Гостайна, гриф СС	Директор и руководство, права равные	2А	3	2
3. ИП	Секреты производства	Один, ко всей информации	3Б	6	5
4. Компания >100	Неконфиденциально	Много, права разные	1Д	6	5
5. Сеть из Интернета	Производственная тайна	Нужны разные права	1Г	5	4
6. Госархив СС/С	Гостайна СС и С	Один заведующий	3А	3	2
7. Энергокомпания	ПДн, платежи, КИИ	Много, нужны разные права	1Г	5	4

ЗАКЛЮЧЕНИЕ

В ходе выполнения лабораторной работы были решены следующие задачи:

- изучены РД «Защита от НСД. Термины и определения» и Концепция защиты от НСД;
- изучен РД «Автоматизированные системы. Защита от НСД» (классификация АС, 30.03.1992);
- изучен РД «Средства вычислительной техники. Защита от НСД» (показатели защищенности СВТ);
- изучен РД «СВТ. Межсетевые экраны. Защита от НСД» (25.07.1997);

- учтён Федеральный закон от 26.07.2017 № 187-ФЗ «О безопасности критической информационной инфраструктуры Российской Федерации»;
- учтён методический документ ФСТЭК «Методика оценки угроз безопасности информации» (утв. 05.02.2021);
- по каждому из семи кейсов обоснованы класс АС, класс СВТ и класс МЭ;
- сделан вывод, в каком порядке начинать решение таких задач.

В ходе лабораторной работы №2 я разобрал РД ФСТЭК (Гостехкомиссии) по терминам, концепции защиты от НСД, классификации АС, показателям защищенности СВТ и МЭ. Ещё посмотрел, как на эти документы накладываются 187-ФЗ и Методика оценки угроз от 5 февраля 2021 г.

Вывод в основном про порядок, а не про заучивание таблицы классов. Начинать не с файрвола и не с антивируса. Сначала смотрим правовой режим информации (открытая / конфиденциальная / гостайна / ПДн / КИИ). Потом — кто субъект доступа и равны ли права. Из этих двух вещей получается группа и класс АС. Под класс АС и гриф берут минимальные классы СВТ и МЭ. Если система ещё и объект КИИ или ИСПДн — поверх классов идут 187-ФЗ (или требования к ИСПДн) и оценка угроз по Методике 2021 г. Уже от угроз собирают СЗИ НСД.

Если шаги переставить, получается как в кейсах: у ИП ставят «как на секретный завод», у архива с СС оставляют бытовой ПК, а у энергокомпании считают, что достаточно предупредить сотрудника, который скачал фейковый установщик. Класс АС без анализа прав и грифа, МЭ без класса АС и «модель угроз» без состава информации — это три разных способа решить задачу с неправильного конца.

Таким образом, все поставленные задачи решены. Цель работы успешно достигнута.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. Руководящий документ. Защита от несанкционированного доступа к информации. Термины и определения : утв. решением председателя Гостехкомиссии России от 30.03.1992.
2. Руководящий документ. Концепция защиты средств вычислительной техники и автоматизированных систем от несанкционированного доступа к информации : утв. решением председателя Гостехкомиссии России от 30.03.1992.
3. Руководящий документ. Автоматизированные системы. Защита от несанкционированного доступа к информации. Классификация автоматизированных систем и требования по защите информации : утв. решением председателя Гостехкомиссии России от 30.03.1992.
4. Руководящий документ. Средства вычислительной техники. Защита от несанкционированного доступа к информации. Показатели защищенности от несанкционированного доступа к информации : утв. решением председателя Гостехкомиссии России от 30.03.1992.
5. Руководящий документ. Средства вычислительной техники. Межсетевые экраны. Защита от несанкционированного доступа к информации. Показатели защищенности от НСД к информации : утв. решением председателя Гостехкомиссии России от 25.07.1997.
6. О безопасности критической информационной инфраструктуры Российской Федерации : федер. закон от 26.07.2017 № 187-ФЗ.
7. Сводная таблица РД ФСТЭК (до профилей защиты) по порядку и в разрезе грифов // Хабр. URL: <https://habr.com/post/311978/>.
8. Методика оценки угроз безопасности информации : методический документ. — М. : ФСТЭК России, 2021 (утв. 05.02.2021).